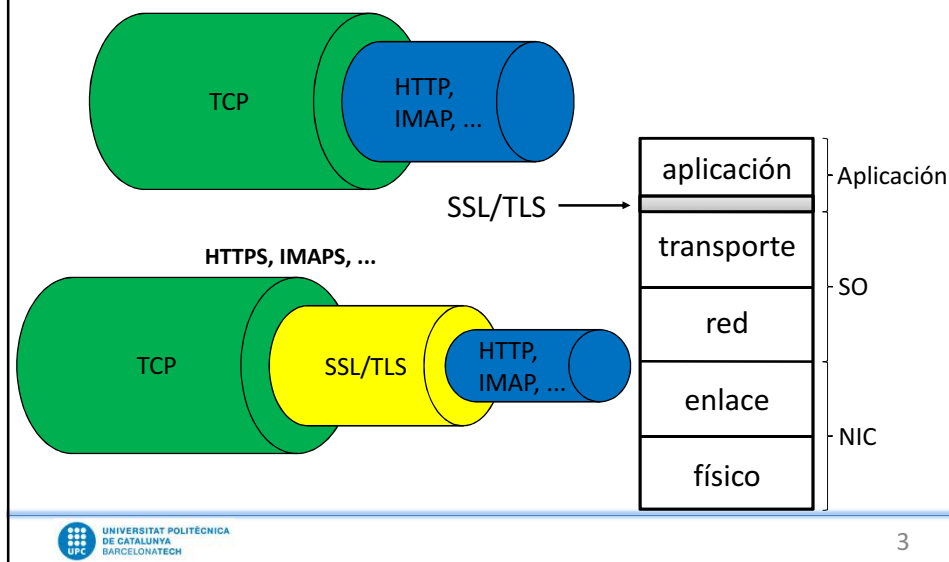


Seguridad de la capa de transporte (TLS)

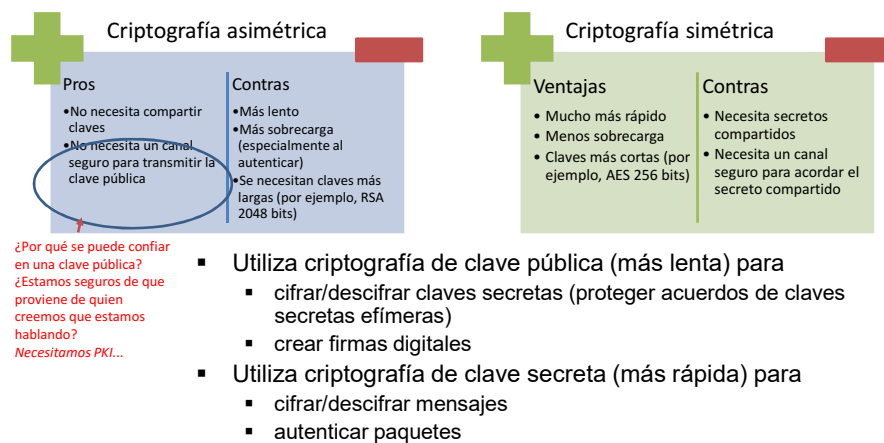
¿Qué es SSL/TLS?

- Transport Layer Security (TLS) y su predecesor, Secure Sockets Layer (SSL), son protocolos criptográficos diseñados para garantizar la seguridad de las comunicaciones en Internet.
- Se utilizan para la mayoría de las transacciones seguras en Internet.
- Objetivos:
 - Autenticación del servidor por el cliente
 - (opcional) Autenticación del cliente por el servidor
 - Proteger todas las comunicaciones en tránsito entre el servidor y el cliente

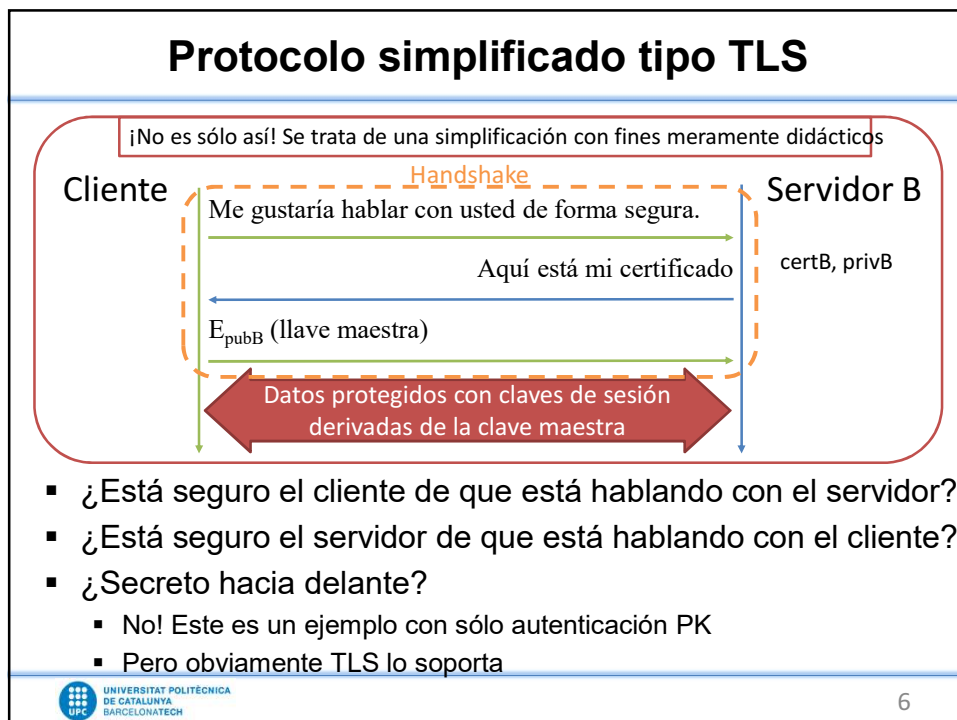
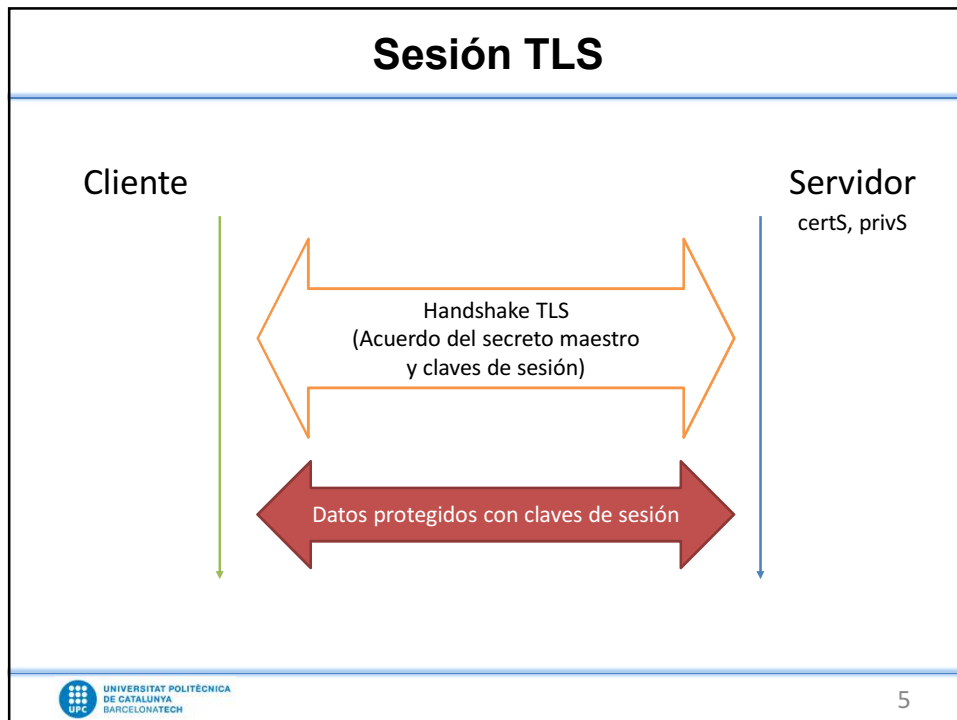
Funcionamiento de SSL/TLS



SSL/TLS es un sistema criptográfico híbrido



Hacer uso de la criptografía asimétrica para acordar claves secretas efímeras.



Comprobaciones comunes de verificación TLS

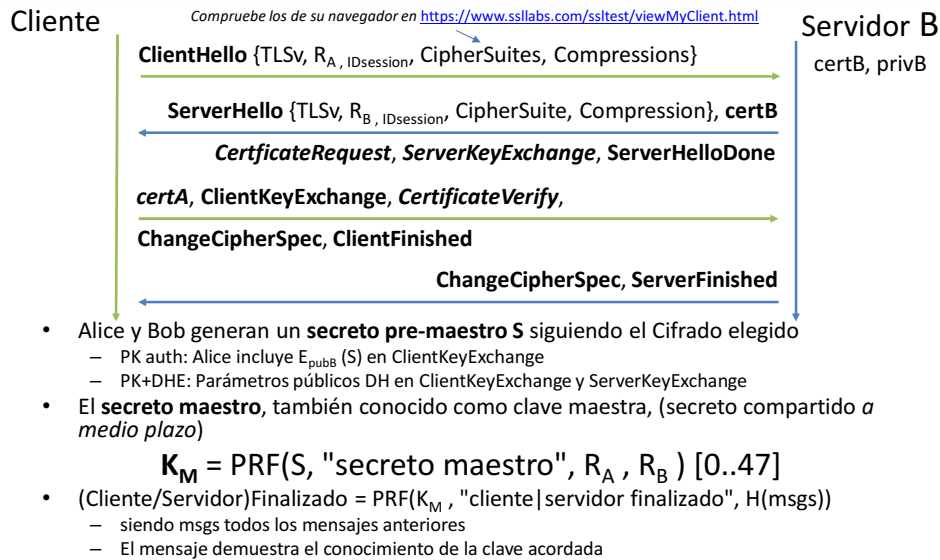
1. El nombre de host completo de la URL de solicitud HTTPS y el propietario del certificado (nombre "Emitido para") deben coincidir.
2. El certificado debe estar actualizado (dentro de su intervalo de fechas "Válido desde...hasta...").
3. El certificado debe haber sido emitido por una autoridad de certificación (CA) de confianza y tener una firma digital válida.
4. El certificado no debe estar revocado (ni CRL ni OCSP).

Las comprobaciones 1-4 se aplican recursivamente a cada certificado de la cadena de confianza.

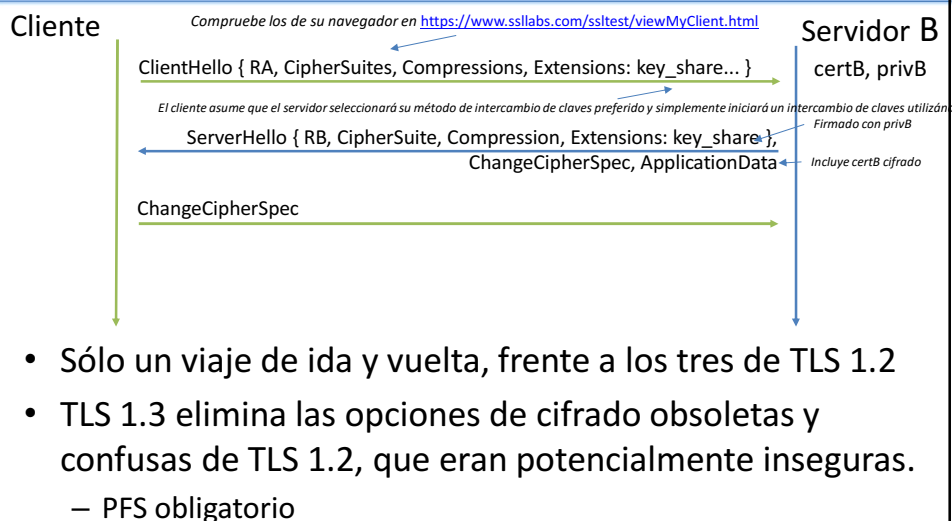
Cronología del TLS

Protocolo	Publicación	Estado
SSL 1.0	No publicado	No publicado
SSL 2.0	1995	Obsoleto en 2011
SSL 3.0	1996	Obsoleto en 2015
TLS v1.0	1999	Obsoleto en 2021
TLS v1.1	2006	Obsoleto en 2021
TLS v1.2	2008	En uso
TLS v1.3	2018	En uso

Sesión TLSv1.2 (simplificada)



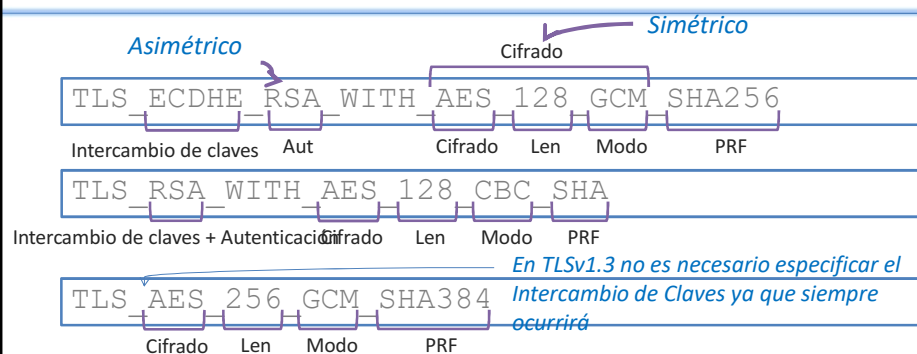
Intercambio TLSv1.3 (simplificado)



Claves de sesión TLS

- Tanto el Cliente como el Servidor utilizarán el secreto maestro K_M para obtener las claves de sesión necesarias:
 - Si se utiliza el modo de funcionamiento de sólo encriptación y autenticación por separado:
 - Autenticación e integridad
 1. client_write_MAC_key
 2. server_write_MAC_key
 - Cifrado
 3. clave_escritura_cliente
 4. clave_escritura_servidor
 - Con modos de funcionamiento de cifrado autenticado (recomendado)
 1. clave_escritura_cliente
 2. server_write_key

Explicación del conjunto de cifrado



Opciones comunes:

KX	Autenticación Handshake	Enc+Aut simétrico	PRF
Sin 		AES-GCM 	SHA256 
ECDHE 	RSA 	CHACHA20 + POLY1305 	SHA384 
DHE 	ECDS 	AES-CBC 	SHA 
	DSS 		

EL ERROR APPLE GOTO FAIL

Errores en la implementación de SSL/TLS



Fallo en la implementación de SSL en goto fail de Apple

- Importante fallo de implementación de SSL en iOS/OSX (admitido por apple en enero de 2014)
- <http://web.nvd.nist.gov/view/vuln/detail?vulnId=CVE-2014-1266>
- "...no comprueba la firma en un mensaje de intercambio de claves de servidor TLS...."
- "...permite a los atacantes man-in-the-middle falsificar servidores SSL mediante (1) el uso de una clave privada arbitraria para el paso de firma u (2) omitiendo el paso de firma."

goto fail Apple SSL bug

```
static OSStatus
SSLVerifySignedServerKeyExchange(SSLContext *ctx, bool isRsa, SSLBuffer signedParams,
                                uint8_t *signature, UInt16 signatureLen)
{
    OSStatus err;
    ...

    if ((err = SSLHashSHA1.update(&hashCtx, &serverRandom)) != 0)
        goto fail;
    if ((err = SSLHashSHA1.update(&hashCtx, &signedParams)) != 0)
        goto fail;
    if ((err = SSLHashSHA1.final(&hashCtx, &hashOut)) != 0)
        goto fail;
    ...

fail:
    SSLFreeBuffer(&signedHashes);
    SSLFreeBuffer(&hashCtx);
    return err;
}
```

EL ERROR HEARTBLEED GNUTLS

Por Eric Larsen, Colin Trettel, Mike Tripp, Curtis
Desmarais



Revelación de OpenSSL



OpenSSL Security Advisory [07 Apr 2014]

TLS heartbeat read overrun (CVE-2014-0160)

A missing bounds check in the handling of the TLS heartbeat extension can be used to reveal up to 64k of memory to a connected client or server.

Only 1.0.1 and 1.0.2-beta releases of OpenSSL are affected including 1.0.1f and 1.0.2-beta1.

Thanks for Neel Mehta of Google Security for discovering this bug and to Adam Langley <agl@chromium.org> and Bodo Moeller <bmoeller@acm.org> for preparing the fix.

Affected users should upgrade to OpenSSL 1.0.1g. Users unable to immediately upgrade can alternatively recompile OpenSSL with `-DOPENSSL_NO_HEARTBEATS`.

1.0.2 will be fixed in 1.0.2-beta2.

¿Qué es el Heartbeat?

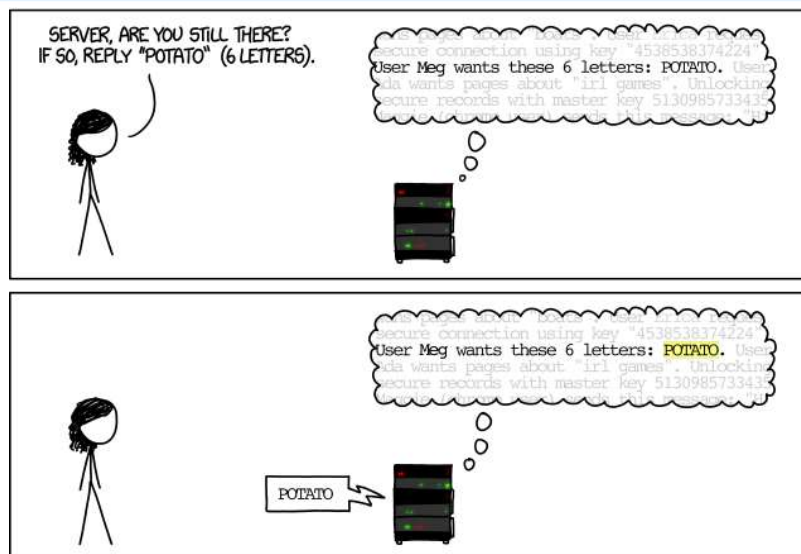
- Extensión OpenSSL
- Petición y respuesta sencillas
 - "¿Sigue ahí?"

!!!Qué es Heartbleed!!!

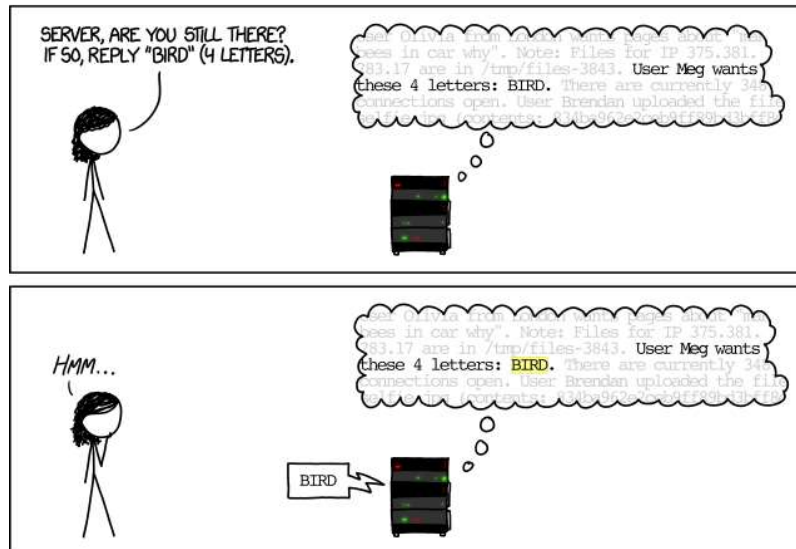
- Fallo de comprobación de límites en SSL Heartbeat
- El 66% de Internet utiliza seguridad OpenSSL
- Ironía del candadito verde
- Reportado **el 7 de abril** de 2014
 - Bug introducido **el 11 de diciembre**



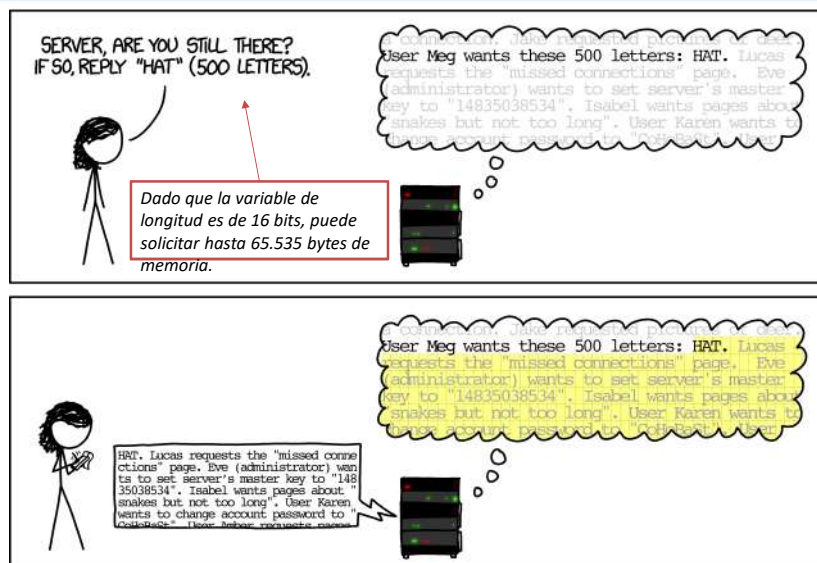
Cómo funciona el fallo Heartbleed (1/3)



Cómo funciona el fallo Heartbleed (2/3)



Cómo funciona el fallo Heartbleed (3/3)



¿Una aguja en un pajar? ¿O acceso fácil a claves privadas?

- Tras el anuncio del fallo Heartbleed, las especulaciones sobre la facilidad de acceso a las claves privadas circularon por Internet.
- Empresas de seguridad web como CloudFlare instalaron una versión vulnerable de SSL en un servidor Nginx y retaron a la comunidad a robar la clave privada
- La empresa pensó que era una hazaña imposible, pero fue resuelta por cuatro individuos diferentes en 24 horas

¿Cuál es la magnitud de Heartbleed?

- OpenSSL 1.0.1 a 1.0.1f (inclusive) son vulnerables al ataque
- Heartbleed existe desde hace años y no se conocen completamente sus efectos totales debido a la capacidad de un atacante para robar información de forma silenciosa.
- No está claro con qué frecuencia ni cuántas personas han explotado este fallo.



Aplicaciones afectadas

- Irónicamente, los servicios más pequeños y progresivos o los que se han actualizado a la última y mejor encriptación serán los más afectados.
- El fallo se introdujo en OpenSSL en diciembre de 2011 y ha estado disponible desde la versión 1.0.1 de OpenSSL, publicada **el 14 de marzo de 2012**. OpenSSL 1.0.1g publicado el **7 de abril de 2014** corrige el error.
- Apache y Nginx son dos grandes aplicaciones que sirven sobre TLS que están afectadas.
- Muchos sitios populares se vieron afectados:
 - Facebook, Instagram, etc.
 - ¡Correo Yahoo!
 - Dropbox
 - ...



EL FALLO DE MICROSOFT SCHANNEL



SChannel

- Secure Channel, también conocido como SChannel, es un proveedor de soporte de seguridad (SSP) que contiene un conjunto de protocolos de seguridad que proporcionan autenticación de identidad y comunicación segura y privada mediante cifrado.
- SChannel se utiliza principalmente para aplicaciones de Internet (MS Windows) que requieren comunicaciones seguras del Protocolo de Transferencia de Hipertexto (HTTP).

Bug SChannel de Microsoft

- En noviembre de 2014, Microsoft admite una vulnerabilidad en SChannel que podría permitir la ejecución remota de código
- El software afectado incluye todos los SO Windows actuales.
- "Los atacantes podrían ejecutar código arbitrario en una larga lista de productos de Microsoft, incluyendo sistemas de escritorio con RDP habilitado y cualquier aplicación web que utilice IIS para HTTPS" - Craig Young (Tripwire)
- "La explotación fiable del bug SChannel tiene el potencial de ser peor que Heartbleed y Shellshock juntos debido al gran número de sistemas afectados."

El fallo SChannel de Microsoft

- La revelación de Microsoft sobre la vulnerabilidad SChannel significa que se ha informado de una vulnerabilidad grave en casi todas las principales pilas TLS en 2014.
- Hasta noviembre de 2014, la más grave había sido el fallo Heartbleed en OpenSSL, pero se le ha unido -y posiblemente superado- la vulnerabilidad SChannel.

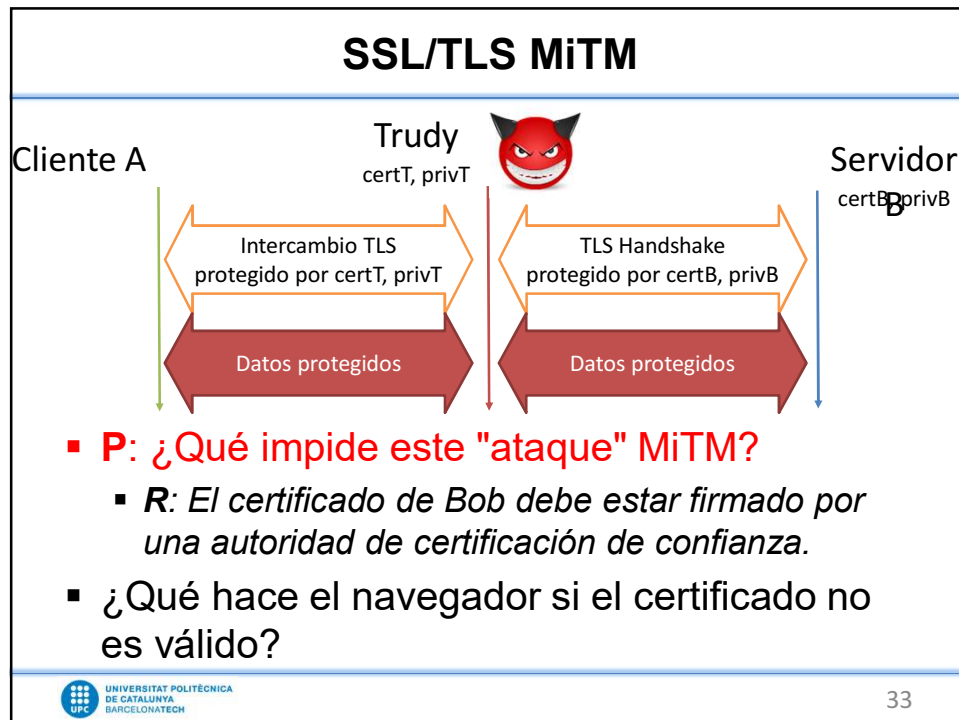
... Y MÁS FALLOS DE TLS

Más fallos... (y vendrán más)

- En septiembre de 2014, una variante de la vulnerabilidad PKCS#1 v1.5 RSA Signature Forgery de Daniel Bleichenbacher fue anunciada por Intel Security Advanced Threat Research. Este ataque, apodado BERserk, es el resultado de una decodificación incompleta de la longitud ASN.1 de las firmas de clave pública en algunas implementaciones SSL, y permite un ataque de hombre en el medio mediante la falsificación de una firma de clave pública.
<https://web.archive.org/web/20150112153121/http://www.intelsecurity.com/advanced-threat-research/>
- En mayo de 2016, se informó de que docenas de sitios web daneses protegidos por HTTPS pertenecientes a Visa Inc. eran vulnerables a ataques que permitían a los hackers inyectar código malicioso y contenido falsificado en los navegadores de los visitantes. Los ataques funcionaron porque la implementación TLS utilizada en los servidores afectados reutilizaba incorrectamente los nonces.
<https://arstechnica.com/information-technology/2016/05/faulty-https-settings-leave-dozens-of-visa-sites-vulnerable-to-forgery-attacks/>
- ...

ATAQUES DE INTERMEDIARIO A TLS/SSL





Los navegadores permiten a los usuarios tomar la última decisión en materia de seguridad

Ayer funcionó, así que...

Your connection is not private

Attackers might be trying to steal your information from [redacted] (for example, passwords, messages, or credit cards).

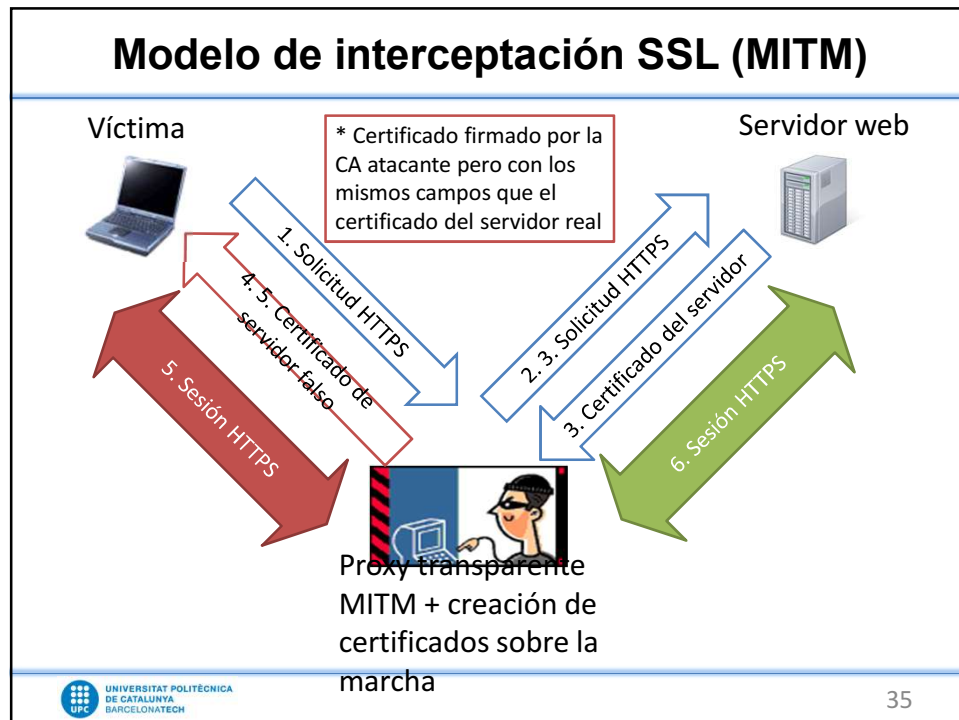
[Advanced](#) [Back to safety](#)

Los efectos de una política "fail open/soft fail"

- 30-70% de los usuarios hacen clic en las advertencias*.
- Anula por completo el propósito de la encriptación.
- No hay forma de cambiar el comportamiento del navegador, hasta hace poco

* <http://www.cs.berkeley.edu/~devdatta/papers/alice-in-warningland.pdf>

34



Herramientas de interceptación SSL

- Existen varios proxies transparentes que implementan el modelo de interceptación SSL para fines "significativos" como el registro de actividades https.
- Probablemente, los más conocidos son
 - [SSLproxy](https://github.com/silentsignal/sslproxy) <https://github.com/silentsignal/sslproxy>
 - [MItMproxy](https://mitmproxy.org/) <https://mitmproxy.org/>

UPC UNIVERSITAT POLITÈCNICA DE CATALUNYA BARCELONATECH

36

SEGURIDAD ESTRICTA DEL TRANSPORTE HTTP (HSTS)

Basado en trabajos anteriores de la fundación OWASP

Seguridad estricta de transporte HTTP (HSTS)

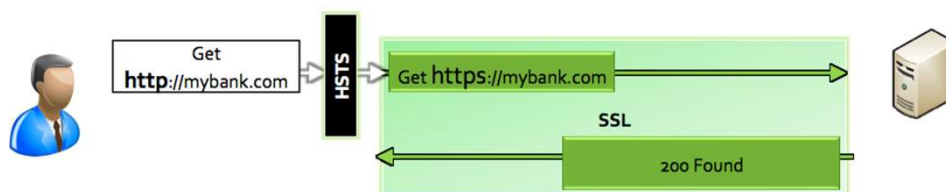
- Publicado en noviembre de 2012
- **HSTS (HTTP Strict Transport Security)** es un mecanismo de seguridad web que obliga a los navegadores a interactuar con un sitio **siempre mediante HTTPS**, evitando conexiones inseguras (HTTP) y protegiendo contra ataques como **downgrade attacks** o **cookie hijacking**.

Cómo funciona

- El servidor web envía un encabezado HTTP en las respuestas:
 - http
 - Strict-Transport-Security: max-age=31536000; includeSubDomains; preload
 - max-age: Tiempo (en segundos) que el navegador recordará usar HTTPS (ej: 1 año = 31,536,000 segundos).
 - includeSubDomains: Aplica HSTS a todos los subdominios.
 - preload: Indica que el sitio está en la lista de precarga de HSTS.
- El navegador almacena esta política y, en futuras visitas:
 - Redirige automáticamente de http:// a https:// (incluso si el usuario escribe HTTP).
 - Bloquea conexiones si el certificado SSL es inválido (sin opción de "continuar igual").

Seguridad estricta de transporte HTTP (HSTS)

- El navegador impide las peticiones HTTP al sitio HSTS
- Cualquier solicitud al sitio se "actualiza" a HTTPS
- Nunca se envía tráfico HTTP de texto claro a un sitio HSTS
- El navegador asume HTTPS para sitios HSTS



Sitios HSTS precargados

- Cambian con cada navegador y versión (diferentes intereses -> diferentes listas)
- Un subconjunto seleccionado de los miembros de la lista HSTS precargada de Chromium/Chrome:
 - Google, Paypal, Twitter, ...
 - Lista completa actualizada: https://src.chromium.org/viewvc/chrome/trunk/src/net/http/transport_security_state_static.json
 - Añadir un dominio a la lista: <https://hstspreload.org/>

- ¿Está tu banco? Supongo que no
- Outlook, ¿Facebook?

Ventajas de HSTS

- Seguridad estricta de transporte HTTP (HSTS)
 - Control de seguridad opcional
 - El sitio web indica al navegador compatible que habilite STS para el sitio
- Fuerzas HSTS (para el sitio habilitado):
 - Toda la comunicación se realiza a través de HTTPS
 - No se envían peticiones HTTP inseguras desde el navegador
 - El usuario no tiene opción de anular los certificados no fiables.
- No afecta a los navegadores antiguos o no compatibles, simplemente no ofrece protección.

HTTPS PRIMERO

Modo HTTPS Primero/Sólo

- Modo de navegador para:
 - actualizar todas las conexiones HTTP a HTTPS
 - Sólo si falla la conexión HTTPS se permite una conexión a HTTP
- Larga historia:
 - Chromium: <https://blog.chromium.org/2021/07/increasing-https-adoption.html>
Q1 2023: Compatibilidad empresarial con el modo HTTPS-First: esta configuración ahora se puede activar de forma forzada a través de la política de empresa, y las empresas pueden especificar una lista opcional de sitios conocidos sólo HTTP. El modo HTTPS-First también se activa automáticamente para los usuarios del Programa de protección avanzada.
 - Firefox: <https://blog.mozilla.org/security/2020/11/17/firefox-83-introduces-https-only-mode/>
<https://blog.mozilla.org/security/2021/08/10/firefox-91-introduces-https-by-default-in-private-browsing/>
 - *Mayo de 2022: El modo HTTPS-Only se activa automáticamente en Firefox para Android, versiones 100 y posteriores.*
- Aún no por defecto... pero a punto de serlo